

UNIVERSIDAD DISTRITAL
FRANCISCO JOSÉ DE CALDAS

Actividad de Aprendizaje No. 2.1: Fase 2 del Proyecto Final

Nicolás Guevara Herrán (20211180026), Jhojan Stiven Aragón Ramírez (20221020060), y Daniel Orlando Villescas Mora (20221020065)

Maestría en Gestión y Seguridad de la Información, Facultad de Tecnología

Universidad Distrital Francisco José de Caldas

Arquitectura de Seguridad

Camilo Enrique Rocha Calderon

22 de septiembre de 2026

Bogotá, D.C.

Índice

Introducción **4**

1. Visión, Principios y Alcance de la Arquitectura **4**

1.1. Carta y Declaración de Propósito (*Charter / Goal Statement*) 4

1.2. Definición del Alcance (*Scope Boundaries*) 5

1.3. Principios de Arquitectura de Seguridad (*Architectural Principles*) 8

1.4. Identificación de Interesados y Puntos de Vista (*Stakeholders & Viewpoints*) 12

2. Contexto de Negocio, Objetivos y Cumplimiento **15**

2.1. Alineación con Objetivos Organizacionales y Tecnológicos 15

2.2. Requerimientos de Cumplimiento y Normativa (*Compliance & Regulatory*) 17

2.3. Tolerancia y Apetito de Riesgo (*Risk Appetite*) 20

3. Evaluación del Estado Actual y Análisis de Brechas **23**

3.1. Efectividad (Capacidad de Reducción de Riesgo) 24

3.2. Madurez (Confiabilidad y Repetibilidad de Procesos) 25

3.3. Eficiencia (Relación Costo/Beneficio) 25

3.4. Análisis de Brechas (Gap Analysis) 26

Matriz Comparativa: Estado Actual vs. Estado Objetivo 26

Desglose Detallado de Brechas Técnicas y de Proceso 27

4. Modelo de Amenazas, Activos y Evaluación de Riesgos **28**

4.1. Inventario y Criticidad de Activos 29

4.2. Caracterización de la Superficie de Ataque 30

4.3. Evaluación de Riesgos Residuales 31

Controles aplicados 32

Valoración residual 33

4.4. Matriz de Dominios de Seguridad 34

5. Arquitectura de Transición y Hoja de Ruta **36**

5.1. Estados de Transición Intermedios 36

5.2. Hoja de Ruta 38

5.3. Matriz de Seguridad SABSA e Integración con Servicios O-ESA 40

Servicios O-ESA y aplicación mediante PDP/PEP 42

6. Métricas **43**

6.1. Indicadores y Métricas de Desempeño (KPI / KRI) 43

7. Conclusiones **45**

Introducción

1. Visión, Principios y Alcance de la Arquitectura

Esta sección explica por qué se requieren cambios en la arquitectura de seguridad del proceso de gestión y despacho de flota desde el Centro de Control Integrado (CCI) de TransMilenio S.A. y qué necesidades debe responder. El documento corresponde a un *blueprint* empresarial (Moyle & Kelley, 2020), porque se enfoca en la infraestructura, las redes, las unidades de negocio y la gobernanza del CCI, y se construye con las fases del TOGAF ADM y los puntos de vista de ArchiMate desarrollados para el caso.

1.1. Carta y Declaración de Propósito (*Charter / Goal Statement*)

La carta de propósito expresa en una o dos oraciones la razón de ser del *blueprint* y el valor estratégico que aporta a la organización. Sirve como criterio para comprobar que cada decisión de diseño posterior responde a ese propósito.

Declaración de propósito para el CCI.

> *Este blueprint define la arquitectura de seguridad del proceso de gestión y despacho de flota desde el CCI de TransMilenio S.A., para que la supervisión y regulación de más de 10.500 buses se apoyen en telemetría auténtica, accesos controlados, decisiones trazables y una operación sin punto único de falla. Con ello protege los objetivos de movilidad segura y de calidad, de consolidación del CCI como centro único de control y de reducción de los tiempos de espera, en cumplimiento de la normativa colombiana de seguridad digital y protección de datos personales.*

La declaración parte de la visión definida en la Fase A del análisis TOGAF: consolidar el CCI como un centro de control integrado, seguro y resiliente, capaz de regular la flota en tiempo real con información confiable. Su valor estratégico se explica por la concentración de la operación. Desde marzo de 2026, y por primera vez en 25 años, la totalidad del sistema (Troncal, TransMiZonal y TransMiCable) se gestiona desde un mismo sitio (TRANSMILENIO S.A., 2026).

Esa concentración mejora la coordinación, pero también hace que un dato manipulado, un acceso indebido o una falla del CCI afecten la operación de toda la ciudad.

Patrocinador: Gerencia General de TransMilenio S.A.

Responsable del dominio: Subgerencia de Operaciones.

Instancia de gobierno: Comité de Arquitectura del proceso, con representación de Operaciones, Seguridad y TI, que revisa cada entrega antes de pasar a producción.

Tipo de *blueprint*: Empresarial, construido con TOGAF ADM y ArchiMate.

Activos críticos protegidos: telemetría de flota (CCI-001), bitácora de decisiones del CCI (CCI-002) y Sistema de Despacho (CCI-003).

1.2. Definición del Alcance (*Scope Boundaries*)

La definición del alcance fija las fronteras de la arquitectura. Indica qué procesos, sistemas, redes y componentes quedan incluidos (*in-scope*) y cuáles quedan excluidos (*out-of-scope*), con la justificación de cada decisión, para que el diseño y la evaluación de riesgos se concentren en lo que soporta el proceso.

La frontera de esta arquitectura es el proceso de gestión y despacho de flota desde el CCI para los componentes Troncal, TransMiZonal y TransMiCable. El proceso comprende la recolección de datos en tiempo real, el análisis de la operación, la toma de decisión operativa y la comunicación y ejecución de las órdenes de regulación. En ArchiMate se modeló como el proceso *Gestión de Irregularidad de Operación*. Las Tablas 1 y 2 presentan los elementos incluidos y la Tabla 3 los excluidos.

Tabla 1

Elementos incluidos en el alcance (in-scope) (parte 1 de 2)

Elemento incluido	Justificación
Proceso de negocio. Gestión y despacho de flota (*Gestión de Irregularidad de Operación*): hallazgo de la irregularidad, recolección de datos de flota, análisis de la operación, toma de decisión operativa, comunicación y ejecución de la orden de regulación.	Es el proceso clave de la Fase B. En sus pasos se materializan los riesgos R1 a R4.
Servicios de negocio. Monitoreo de Flota en Tiempo Real, Notificación de Novedades Operacionales y Notificación de Instrucciones de Regulación.	Son los servicios que el proceso entrega a supervisores, operadores de flota y conductores. Sobre ellos se asocian los requerimientos de seguridad.
Activos de información críticos. Telemetría de flota (CCI-001), bitácora de decisiones del CCI (CCI-002) y Sistema de Despacho (CCI-003), junto con los objetos de negocio Novedad Operacional e Instrucción de Regulación.	Los tres activos tienen criticidad Alta en la valoración de confidencialidad, integridad y disponibilidad (Anexo A).
Aplicaciones. Sistema de Despacho / Control de Flota (SIRCI/FMS) con sus módulos de monitoreo de flota, gestión de novedades y despacho y regulación; plataforma de analítica y tableros operativos; consola unificada del CCI.	Soportan cada paso del proceso, desde la actualización del estado de la flota hasta la generación de instrucciones de regulación.

Tabla 2

Elementos incluidos en el alcance (in-scope) (parte 2 de 2)

Elemento incluido	Justificación
Sistema ITS a bordo y red vehículo–CCI. GPS/AVL, cámaras y sensores de los buses, y la red de comunicaciones que transmite la telemetría al CCI.	Es el origen de la telemetría. Sin su protección no se puede garantizar la integridad de la señal (R1).
Integraciones. Bus de eventos en tiempo real y APIs entre ITS a bordo, despacho, analítica, alertas e información al usuario.	El análisis de la Fase 1 mostró que los riesgos más críticos se concentran en los puntos de integración entre subsistemas.
Identidad y acceso. SSO con Active Directory y ADFS, perfiles RBAC y MFA para las más de 200 personas que operan desde 209 puestos.	Un acceso no autorizado al Sistema de Despacho (R3) permite cambiar rutas, frecuencias u órdenes de despacho.
Infraestructura tecnológica del CCI. Centro de datos local de baja latencia, servicios en Google Cloud Platform, Fortinet (firewalls, segmentación, FortiAnalyzer y FortiSIEM), Oracle Spatial/Locator con Esri ArcGIS, plataforma de streaming de eventos y almacenamiento WORM.	Soporta la disponibilidad del despacho (R4) y la integridad de los registros de decisiones (R2).
Interfaces con procesos externos. Entrada de alertas desde la gestión de incidentes y emergencias, y salida de novedades hacia los canales de información al usuario.	Son los eventos que disparan una acción de regulación o comunican su resultado, por lo que su contenido y su canal deben protegerse.

Nota. Elaboración propia con base en el análisis TOGAF de la Fase 1 y TRANSMILENIO S.A. (2020, 2026).

Tabla 3
Elementos excluidos del alcance (out-of-scope)

Elemento excluido	Justificación
Gestión de incidentes y emergencias: video-analítica con inteligencia artificial, cadena de custodia de evidencia digital e intercambio de información con la Policía.	Es un proceso externo con su propio caso de negocio (caso 2). Solo se incluye la interfaz por la que sus alertas llegan al CCI.
Recaudo del SIRCI: medios de pago, validadores y liquidación de ingresos.	No interviene en la supervisión ni en la regulación de la flota.
Sistemas internos de los operadores de flota: gestión de mantenimiento, personal y nómina de los consorcios troncales y zonales.	Los administran terceros. La arquitectura cubre su conexión con el CCI y las obligaciones de seguridad que se les trasladen.
Canales digitales de atención al ciudadano: desarrollo y operación de la aplicación móvil, el sitio web y las pantallas de las estaciones.	El alcance llega hasta la publicación de la novedad. La seguridad propia de esas aplicaciones corresponde a un *blueprint* de aplicación.
Sistemas de control mecánico y electrónico del vehículo (motor, frenos y red interna del bus).	Corresponden a la seguridad funcional del vehículo y no a la seguridad de la información del proceso.
Procesos administrativos y financieros de TransMilenio (contratación, gestión financiera y talento humano).	No soportan la regulación de la flota.

Nota. Elaboración propia con base en el análisis TOGAF de la Fase 1.

1.3. Principios de Arquitectura de Seguridad (*Architectural Principles*)

Los principios de arquitectura de seguridad son reglas generales y no negociables que orientan las decisiones de diseño. Cada principio se documenta con un nombre, una declaración de la regla, la justificación de negocio que lo respalda y las implicaciones técnicas y operativas que genera.

Los principios retoman los definidos en la Fase Preliminar del análisis TOGAF. Los tres primeros se modelaron en la *Goal Realization View*, donde realizan los resultados esperados (*outcomes*) del CCI. El cuarto se presenta en su dimensión de seguridad, porque las integraciones concentran los riesgos más críticos del proceso.

Principio 1.

Nombre: Seguridad desde el diseño (*Security by Design*).

Declaración: Todo componente que soporta el proceso de despacho incorpora control de acceso,

cifrado, integridad y trazabilidad desde su concepción, y ningún usuario ni consola del CCI opera sin autenticarse de forma robusta.

Justificación: El CCI concentra en un solo sitio la regulación de toda la flota. Un control añadido después de la puesta en producción deja expuestos el acceso no autorizado al despacho (R3) y la alteración de la bitácora (R2). El principio está en línea con el MSPI, que incluye la seguridad en la adquisición, el desarrollo y el mantenimiento de los sistemas (Ministerio de Tecnologías de la Información y las Comunicaciones, 2021).

Implicaciones:

- RBAC con perfiles diferenciados (operador de monitoreo, supervisor de despacho y soporte TIC) sobre Active Directory y ADFS, y MFA en las consolas y cuentas del CCI.
- Cifrado de las comunicaciones operativas y de los datos personales, y registro de cada decisión en almacenamiento WORM.
- Monitoreo centralizado de accesos y eventos de seguridad con FortiSIEM y FortiAnalyzer.
- Revisión de cada entrega por el Comité de Arquitectura y pruebas de penetración a las consolas antes de pasar a producción.
- En la operación, la creación de cuentas requiere la aprobación del rol, y los operadores usan MFA al iniciar sesión en las consolas.

Relación con el modelo: realiza los *outcomes* “Cero hallazgos críticos en auditorías de datos personales”, “Cero accesos no autorizados al Sistema de Despacho” y “100 % de las decisiones de despacho registradas sin alteraciones”.

Principio 2.

Nombre: Dato único y consistente.

Declaración: La posición, el estado y la programación de la flota tienen una sola fuente autoritativa, y ninguna decisión de despacho se toma con una señal GPS/AVL cuya autenticidad no se haya verificado.

Justificación: El CCI procesa más de 40 millones de registros de datos al día (TRANSMILENIO S.A., 2026). Si dos sistemas muestran posiciones distintas o si una señal fue suplantada (R1), el supervisor regula la flota con información falsa, lo que altera las frecuencias del servicio y los tiempos de espera.

Implicaciones:

- Definir la fuente autoritativa y los metadatos comunes de flota: código de bus, ruta, servicio, estación o parada y marca de tiempo.
- Usar Oracle Spatial/Locator como fuente transaccional y Esri ArcGIS solo como capa de publicación y análisis.
- Validar criptográficamente la señal GPS/AVL antes de que llegue al despacho y marcar como no confiable cualquier dato que no supere la validación.
- Hacer que los tableros operativos consuman la fuente autoritativa y no copias locales de los datos.

Relación con el modelo: realiza los *outcomes* "100 % de las señales GPS/AVL con autenticidad verificada antes de usarse" y "100 % de las decisiones de despacho registradas sin alteraciones".

Principio 3.

Nombre: Continuidad operativa.

Declaración: El CCI no es un punto único de falla. La supervisión y la regulación de la flota continúan ante la falla de un componente, de un enlace o del sitio principal.

Justificación: La operación es continua (8.760 horas al año) y la indisponibilidad del Sistema de Despacho (R4) tiene impacto Mayor, porque impide aplicar medidas frente a retrasos, congestión y otras novedades de la operación.

Implicaciones:

- Arquitectura redundante que combina componentes locales de baja latencia con servicios en Google Cloud Platform y balanceadores de carga.
- Plan de contingencia del CCI con procedimientos de regulación en modo degradado, probados de forma periódica.
- Meta de disponibilidad del Sistema de Despacho igual o superior al 99.9 % en horas pico, propuesta como supuesto del modelo académico.
- Mayor costo de infraestructura y de pruebas, que se planifica en la fase 3 de la migración (Fase F).

Relación con el modelo: realiza el *outcome* "Uptime ≥ 99.9 % del Sistema de Despacho en horas pico".

Principio 4.

Nombre: Integración segura por API o bus de eventos.

Declaración: Los sistemas del proceso intercambian información solo a través de APIs o del bus de eventos en tiempo real, con autenticación de cada sistema y canales cifrados. No se permiten integraciones punto a punto sin documentar.

Justificación: La Fase Preliminar adoptó este mecanismo como directriz de interoperabilidad. Las conclusiones de la Fase 1 muestran que una falla o manipulación en un subsistema (ITS a bordo, despacho, analítica o información al usuario) puede propagarse a toda la operación a través de esos puntos de integración.

Implicaciones:

- Mantener actualizado el inventario de interfaces, fuentes de datos, roles y permisos.
- Autenticar cada sistema que publica o consume eventos y cifrar el canal de intercambio.
- Segmentar la red con Fortinet para separar funciones críticas, sistemas operacionales, analítica y accesos externos.
- Aplicar los metadatos comunes del principio 2 a todos los eventos del bus.

Relación con el modelo: no se modeló en la *Goal Realization View* porque su propósito principal es la interoperabilidad. Se apoya en el requerimiento "Inventario de activos, interfaces, roles y permisos".

1.4. Identificación de Interesados y Puntos de Vista (*Stakeholders & Viewpoints*)

Este ítem identifica a los actores con interés en la arquitectura y los clasifica según su rol: beneficiarios del servicio, tomadores de decisiones y especialistas técnicos. Para cada uno indica su preocupación principal y los puntos de vista que le muestran la información que necesita.

Los interesados provienen del mapa de la Fase A y son los mismos que se modelaron en la *Stakeholder View*. Su preocupación principal corresponde a los impulsadores (*drivers*) con los que se asociaron en esa vista, como se resume en las Tablas 4 y 5.

Tabla 4

Interesados, preocupaciones y puntos de vista (parte 1 de 2)

Rol	Interesado	Preocupación principal (*driver* asociado)	Puntos de vista
Beneficiario	Usuarios del sistema	Indisponibilidad del Sistema de Despacho: si no se puede regular la flota, aumentan los tiempos de espera y la variabilidad del servicio.	*Stakeholder View*, donde se representan sus intereses.
Tomador de decisiones	Gerencia General (patrocinador)	Cumplimiento normativo de seguridad y datos personales, e indisponibilidad del Sistema de Despacho. Aprueba la visión y recibe el informe de estado de la arquitectura (Fase H).	*Stakeholder View* y *Goal Realization View*.
Tomador de decisiones	Subgerencia de Operaciones	Acceso no autorizado al Sistema de Despacho e indisponibilidad del Sistema de Despacho. Es la responsable principal del dominio operativo.	*Stakeholder View*, *Goal Realization View* y vista integrada.

Tabla 5

Interesados, preocupaciones y puntos de vista (parte 2 de 2)

Rol	Interesado	Preocupación principal (*driver* asociado)	Puntos de vista
Especialista técnico (operación)	Direcciones Técnicas Troncal y Zonal	Acceso no autorizado al Sistema de Despacho e indisponibilidad del Sistema de Despacho, porque regulan su componente desde el CCI.	Vista integrada (servicios y proceso).
Especialista técnico (TI)	Dirección TIC y áreas de analítica de datos	Cumplimiento normativo, manipulación de la telemetría GPS/AVL y alteración de la bitácora de decisiones. Administra los sistemas, las identidades y los registros.	*Goal Realization View* y vista integrada (requerimientos y componentes de aplicación).
Especialista técnico (operación)	Operadores de flota y conductores	Manipulación de la telemetría GPS/AVL, porque la señal sale del ITS a bordo de sus buses y con base en ella reciben las órdenes de regulación.	Vista integrada (servicio Notificación de Instrucciones de Regulación).
Especialista técnico (seguridad física)	Dirección Técnica de Seguridad y organismos externos	Cumplimiento normativo de seguridad y datos personales. Participan solo cuando una novedad afecta la operación.	*Stakeholder View* y vista integrada (servicio Notificación de Novedades Operacionales).

Nota. Elaboración propia con base en el mapa de interesados de la Fase A y la Stakeholder View del modelo ArchiMate.

Los puntos de vista desarrollados en ArchiMate responden a estas necesidades de la siguiente manera:

- ***Stakeholder View*:** relaciona los siete interesados con cinco impulsadores, cinco evaluaciones (*assessments*) y cinco objetivos (*goals*). Le muestra a la dirección por qué se requiere el cambio.
- ***Goal Realization View*:** descompone los cinco objetivos en resultados esperados medibles y los vincula con tres principios y diez requerimientos de seguridad. Le sirve a la dirección para acordar metas y a la Dirección TIC para saber qué debe implementar.
- **Vista integrada de motivación, estrategia, negocio y aplicación:** conecta los requerimientos con los cursos de acción, los tres servicios de negocio, el proceso *Gestión de*

Irregularidad de Operación, sus objetos de negocio y el componente SIRCI/FMS. La usan la operación y TI para ubicar en qué paso del proceso y en qué aplicación se aplica cada control.

2. Contexto de Negocio, Objetivos y Cumplimiento

TransMilenio S.A. es una empresa industrial y comercial del Estado del orden distrital, adscrita a la Alcaldía Mayor de Bogotá, que gestiona el transporte público masivo de la ciudad en sus componentes Troncal, TransMiZonal y TransMiCable. Desde marzo de 2026 el CCI supervisa en un mismo sitio más de 10.500 buses, procesa más de 40 millones de registros de datos al día y opera desde 209 puestos (Alcaldía Mayor de Bogotá, 2026; TRANSMILENIO S.A., 2026). Esta sección relaciona ese contexto con los objetivos de la organización, la normativa aplicable y el nivel de riesgo que la entidad está dispuesta a asumir.

2.1. Alineación con Objetivos Organizacionales y Tecnológicos

La alineación muestra cómo cada decisión de seguridad habilita una meta misional del negocio y qué capacidad tecnológica requiere. Su propósito es que cada control se justifique por el objetivo que protege y no solo como una buena práctica.

Los objetivos que orientan la arquitectura son los objetivos estratégicos del caso y un objetivo tecnológico del Plan Estratégico de Tecnologías de la Información (PETI):

- **OE1.** Garantizar una movilidad urbana sostenible, segura y de calidad para los habitantes de Bogotá.
- **OE2.** Integrar y modernizar la operación del sistema mediante tecnología, consolidando el CCI como centro único de control.
- **OE3.** Reducir los tiempos de espera y la variabilidad del servicio mediante regulación de flota en tiempo real.
- **OT1.** Reflejar correctamente las actuaciones de la institución y de sus terceros, según el PETI (TRANSMILENIO S.A., 2020).

La Tabla 6 muestra, para cada objetivo, la decisión de seguridad que lo habilita, expresada como curso de acción y requerimientos del modelo ArchiMate, la capacidad tecnológica que esa decisión exige y el objetivo de seguridad (*goal*) con su resultado esperado (*outcome*).

Tabla 6

Alineación de las decisiones de seguridad con los objetivos organizacionales y tecnológicos

Objetivo	Decisión de seguridad (curso de acción y requerimientos)	Capacidad tecnológica requerida	*Goal* y *outcome*
OE3, OE2	*Fortalecer integridad y fuentes autoritativas de telemetría*: validación criptográfica de la señal GPS/AVL; fuente autoritativa y metadatos comunes de flota.	Telemetría autenticada desde el ITS a bordo, plataforma de streaming de eventos y base geoespacial como fuente única de posición y estado de la flota.	Integridad de datos geoespaciales: 100 % de las señales GPS/AVL con autenticidad verificada antes de usarse.
OE3, OE1	*Implementar contingencia y redundancia integral del CCI* y *Consolidar monitoreo y protección transversal de seguridad*: arquitectura redundante del CCI; plan de contingencia del CCI; monitoreo centralizado con FortiSIEM/FortiAnalyzer.	Componentes locales de baja latencia con respaldo en Google Cloud Platform, balanceadores de carga, procedimientos de operación en modo degradado y detección temprana de fallas y ataques.	Disponibilidad y resiliencia operativa: uptime ≥ 99.9 % del Sistema de Despacho en horas pico.
OE2	*Fortalecer control de acceso con RBAC y MFA*: RBAC con perfiles diferenciados (AD + ADFS); MFA en consolas y cuentas del CCI.	SSO centralizado con perfiles para operador de monitoreo, supervisor de despacho y soporte TIC en todas las consolas del CCI.	Control de acceso robusto y protección de datos: cero accesos no autorizados al Sistema de Despacho.
OE1, OT1	*Formalizar trazabilidad y auditoría de decisiones operativas*: registro de decisiones en almacenamiento WORM.	Bitácora automática que registra el dato o evento de origen, el responsable, la instrucción emitida y el resultado, sobre almacenamiento inmutable.	Trazabilidad de instrucciones: 100 % de las decisiones de despacho registradas sin alteraciones.
OE1, OE2	*Fortalecer cumplimiento y protección de datos personales del CCI*: inventario de activos, interfaces, roles y permisos; cifrado de comunicaciones y datos personales.	Inventario de activos según el formato del MSPI, cifrado de la información en tránsito y minimización de datos personales en los tableros operativos.	Alineación del CCI con normativa legal de datos personales: cero hallazgos críticos en auditorías de datos personales.

Nota. Elaboración propia con base en los objetivos estratégicos del caso, TRANSMILENIO S.A. (2020, 2026) y las vistas ArchiMate del modelo.

La tabla sigue la misma cadena de los modelos ArchiMate. Cada objetivo organizacional se protege con un objetivo de seguridad, este se mide con un resultado esperado y se realiza

mediante principios y requerimientos concretos. Los requerimientos, a su vez, se asocian en la vista integrada con los servicios Monitoreo de Flota en Tiempo Real, Notificación de Novedades Operacionales y Notificación de Instrucciones de Regulación, de modo que cada control queda ubicado en el servicio de negocio que protege. El orden de implementación sigue la Fase F: primero las fuentes autoritativas, el control de acceso por roles y la trazabilidad básica; después la integración y el tablero unificado; y al final la redundancia integral y la auditoría transversal de decisiones.

2.2. Requerimientos de Cumplimiento y Normativa (*Compliance & Regulatory*)

Este ítem cataloga los marcos legales, regulatorios y estándares que son obligatorios o de referencia para el alcance, indica qué exige cada uno y cómo responde la arquitectura. Permite demostrar ante una auditoría que cada control tiene un soporte normativo.

El CCI procesa datos de geolocalización, video de cámaras a bordo, datos personales de usuarios y conductores e información operativa crítica. Por ese tipo de información y por su condición de entidad pública, le aplican los marcos de las Tablas 7 y 8.

Tabla 7

Marcos legales, regulatorios y estándares aplicables al alcance (parte 1 de 2)

Marco	Carácter	Exigencia aplicable al CCI	Respuesta de la arquitectura
Ley Estatutaria 1581 de 2012 (Congreso de Colombia, 2012)	Ley, obligatoria	Tratar los datos personales de conductores y usuarios (identificación asociada al vehículo, geolocalización e imágenes de cámaras a bordo) según los principios de finalidad, acceso y circulación restringida, seguridad y confidencialidad.	RBAC, cifrado de comunicaciones y datos personales, minimización de datos personales en los tableros y clasificación de la información del ITS.
Decreto 1074 de 2015 (Ministerio de Comercio, Industria y Turismo, 2015)	Decreto reglamentario, obligatorio	Contar con política de tratamiento, autorización de los titulares, aviso de privacidad, procedimiento de consultas y reclamos, e inscripción de las bases de datos en el Registro Nacional de Bases de Datos.	Política de Tratamiento y Protección de Datos Personales (v6) e identificación, en el inventario de activos, de las bases con datos personales.
Resolución MinTIC 500 de 2021, MSPI (Ministerio de Tecnologías de la Información y las Comunicaciones, 2021)	Resolución, obligatoria para entidades públicas	Adoptar el Modelo de Seguridad y Privacidad de la Información: inventario y clasificación de activos, gestión de riesgos de seguridad de la información, plan de tratamiento y gestión de incidentes.	Inventario de activos (Anexo A), matriz de riesgos y controles (Anexo B), MFA, RBAC y registro de decisiones.
Decreto 338 de 2022 (Presidencia de la República de Colombia, 2022)	Decreto, obligatorio	Fortalecer la gobernanza de la seguridad digital, identificar y proteger las infraestructuras críticas cibernéticas y los servicios esenciales, gestionar sus riesgos y responder a los incidentes de seguridad digital.	Tratamiento del CCI como infraestructura crítica de movilidad: arquitectura redundante, plan de contingencia, monitoreo con FortiSIEM y segmentación de red.
Ley 1712 de 2014 (Congreso de Colombia, 2014a)	Ley, obligatoria	Determinar qué información es pública, clasificada o reservada, y publicar la información al ciudadano sin exponer la que tiene reserva.	Clasificación de la información del CCI y publicación de novedades al usuario sin datos personales ni detalles de la infraestructura.

Tabla 8

Marcos legales, regulatorios y estándares aplicables al alcance (parte 2 de 2)

Marco	Carácter	Exigencia aplicable al CCI	Respuesta de la arquitectura
ISO/IEC 27001:2022 (International Organization for Standardization & International Electrotechnical Commission, 2022a)	Estándar internacional, de referencia	Sistema de gestión de seguridad de la información y controles del Anexo A. El MSPI toma esta norma como referencia.	Base de los controles asociados a cada requerimiento (Tabla 9).
ISO/IEC 27005:2022 (International Organization for Standardization & International Electrotechnical Commission, 2022b)	Estándar internacional, de referencia	Orientación para identificar, analizar, evaluar y tratar los riesgos de seguridad de la información.	Identificación de R1 a R4 a partir de activos, amenazas y debilidades.
Guía para la Gestión Integral del Riesgo en Entidades Públicas, v7 (Departamento Administrativo de la Función Pública, 2025)	Guía metodológica para entidades públicas	Escalas de probabilidad e impacto, matriz de calor, diseño de controles, riesgo residual y definición del apetito de riesgo.	Valoración del riesgo inherente y criterios de apetito del numeral 2.3.
PESI v2 (TRANSMILENIO S.A., 2025a), Políticas de Seguridad y Privacidad de la Información (v7) y Política de Tratamiento y Protección de Datos Personales (v6)	Políticas internas, obligatorias	Lineamientos institucionales de control de acceso, autenticación, continuidad y protección de datos personales.	MFA, RBAC, arquitectura redundante y cifrado de comunicaciones y datos personales.
PETI v2 (TRANSMILENIO S.A., 2020)	Plan institucional, obligatorio	Reflejar correctamente las actuaciones de la institución y de sus terceros.	Registro de decisiones en almacenamiento WORM.

Nota. Elaboración propia con base en las regulaciones del caso de negocio 1 y las referencias citadas.

La Tabla 9 relaciona cada requerimiento de seguridad de la *Goal Realization View* con la norma que lo exige o respalda y con el control del Anexo A de ISO/IEC 27001:2022 que le corresponde.

Tabla 9

Trazabilidad entre requerimientos de seguridad y normativa

Requerimiento	Respaldo normativo	Control ISO/IEC 27001:2022 (Anexo A)
Inventario de activos, interfaces, roles y permisos	Res. MinTIC 500 de 2021 (MSPI)	5.9 Inventario de activos
MFA en consolas y cuentas del CCI	Res. MinTIC 500 de 2021; PESI v2	8.5 Autenticación segura
RBAC con perfiles diferenciados (AD + ADFS)	Ley 1581 de 2012 (acceso y circulación restringida); Res. MinTIC 500 de 2021	5.15 Control de acceso; 5.18 Derechos de acceso; 8.2 Derechos de acceso privilegiado
Cifrado de comunicaciones y datos personales	Ley 1581 de 2012 (seguridad); Política de Tratamiento de Datos Personales v6	8.24 Uso de criptografía; 5.34 Privacidad y protección de datos personales
Registro de decisiones en almacenamiento WORM	PETI v2; Res. MinTIC 500 de 2021	8.15 Registro de eventos; 5.33 Protección de registros
Monitoreo centralizado con FortiSIEM/FortiAnalyzer	Decreto 338 de 2022; Res. MinTIC 500 de 2021	8.16 Actividades de monitoreo
Fuente autoritativa y metadatos comunes de flota	Principio de arquitectura de la Fase Preliminar; sin exigencia normativa directa	No aplica
Validación criptográfica de la señal GPS/AVL	Decreto 338 de 2022 (protección de infraestructura crítica)	8.24 Uso de criptografía
Arquitectura redundante del CCI	Decreto 338 de 2022	8.14 Redundancia de las instalaciones de procesamiento
Plan de contingencia del CCI	Decreto 338 de 2022; Res. MinTIC 500 de 2021	5.29 Seguridad durante una interrupción; 5.30 Preparación de las TIC para la continuidad

Nota. Elaboración propia con base en International Organization for Standardization y International Electrotechnical Commission (2022a) y la normativa de las Tablas 7 y 8.

Las leyes, los decretos, la resolución y las políticas internas son de cumplimiento obligatorio. Las normas ISO/IEC son de referencia y se aplican por medio del MSPI. El resultado esperado “Cero hallazgos críticos en auditorías de datos personales” es la medida con la que se verifica este cumplimiento.

2.3. Tolerancia y Apetito de Riesgo (*Risk Appetite*)

El apetito de riesgo es el nivel de riesgo que la organización está dispuesta a aceptar para lograr sus objetivos. La tolerancia es la desviación máxima que admite sobre ese nivel, y la

capacidad de riesgo es el nivel máximo que puede soportar sin comprometer sus objetivos (Departamento Administrativo de la Función Pública, 2025). Juntos fijan el umbral que decide qué riesgos se aceptan, cuáles requieren controles y en qué orden se tratan.

La Guía del Departamento Administrativo de la Función Pública indica que cada entidad define estos niveles en su política de administración del riesgo. Los documentos del caso no incluyen el apetito formal de TransMilenio, por lo que este *blueprint* propone los parámetros de la Tabla 10 para el proceso del CCI. Los parámetros usan las zonas de la matriz de calor del riesgo inherente de la Fase 1 y la meta, fijada en esa valoración, de llevar los riesgos a niveles bajos o moderados.

Tabla 10

Apetito, tolerancia y capacidad de riesgo propuestos para el CCI

Zona de riesgo	Posición	Decisión de tratamiento	Seguimiento
Bajo	Dentro del apetito	Aceptar el riesgo y mantener los controles existentes.	Revisión semestral de la arquitectura (Fase H).
Moderado	Dentro de la tolerancia	Aceptar de forma temporal, solo con un plan de tratamiento aprobado por el Comité de Arquitectura y un responsable asignado.	Trimestral.
Alto	Supera la tolerancia	Reducir con controles. No se acepta como nivel de riesgo residual.	Mensual, hasta llegar a Moderado o Bajo.
Extremo	Supera la capacidad de riesgo	Reducir o evitar de inmediato y escalar a la Gerencia General.	Inmediato.

Nota. Elaboración propia con base en Departamento Administrativo de la Función Pública (2025).

La tolerancia también se expresa por propiedad de seguridad, con los mismos valores de los resultados esperados de la *Goal Realization View* (Tabla 11).

Tabla 11
Tolerancia por propiedad de seguridad

Propiedad (riesgo)	Tolerancia	Justificación
Integridad de la telemetría (R1)	Cero decisiones de despacho tomadas con señales GPS/AVL sin autenticidad verificada.	Un dato falso no se detecta a simple vista y puede afectar la regulación de varios vehículos a la vez.
Integridad de la bitácora (R2)	Cero registros alterados o eliminados; 100 % de las decisiones registradas.	Sin registros íntegros no hay evidencia de las decisiones ni responsables verificables.
Control de acceso al despacho (R3)	Cero accesos no autorizados; MFA en el 100 % de las consolas y cuentas del CCI que lo soporten.	Una orden no autorizada cambia rutas, frecuencias u órdenes de despacho de la flota en vía.
Disponibilidad del despacho (R4)	Indisponibilidad máxima del 0.1 % del tiempo en horas pico (uptime $\geq$ 99.9 %), como supuesto del modelo académico.	Una falla de disponibilidad es visible y el plan de contingencia permite regular en modo degradado, por eso admite un margen mínimo.
Cumplimiento normativo	Cero hallazgos críticos en auditorías de datos personales y del MSPI.	Un hallazgo crítico expone a la entidad a sanciones de la Superintendencia de Industria y Comercio, autoridad de protección de datos personales.

Nota. Elaboración propia con base en la Goal Realization View del modelo ArchiMate.

La tolerancia es menor para la integridad y el control de acceso que para la disponibilidad. La manipulación de la telemetría y las órdenes no autorizadas pueden pasar desapercibidas y llevar a decisiones incorrectas, mientras que una caída del despacho se detecta de inmediato y cuenta con un procedimiento de contingencia.

Con estos parámetros, los cuatro riesgos evaluados en la Fase 1 superan la tolerancia, porque todos tienen nivel inherente Alto (Tabla 12).

Tabla 12

Posición de los riesgos inherentes frente al apetito de riesgo

Riesgo	Nivel inherente	Posición	Residual objetivo	Prioridad
R1. Manipulación de la telemetría de flota	Alto (80 %)	Supera la tolerancia	Moderado o inferior	1
R3. Acceso no autorizado al Sistema de Despacho	Alto (80 %)	Supera la tolerancia	Moderado o inferior	1
R4. Indisponibilidad del Sistema de Despacho	Alto (80 %)	Supera la tolerancia	Moderado o inferior	2
R2. Alteración de la bitácora de decisiones	Alto (60 %)	Supera la tolerancia	Moderado o inferior	3

Nota. Elaboración propia con base en la valoración del riesgo inherente de la Fase 1.

Los controles se priorizan con tres criterios, en este orden: primero, los riesgos cuyo nivel supera la tolerancia; segundo, los de mayor severidad; y tercero, a igual severidad, la propiedad con tolerancia cero (integridad y control de acceso) antes que la disponibilidad. Por eso R1 y R3 tienen prioridad 1, R4 prioridad 2 y R2 prioridad 3. Mientras se implementa la redundancia integral de R4, prevista para la fase 3 de la migración, el plan de contingencia del CCI cubre el periodo intermedio. La prioridad 3 de R2 no impide aplicar antes sus controles de bajo costo, porque el registro automático de decisiones es un *quick win* de la Fase E.

La matriz de calor impone una condición adicional. Todas las celdas de impacto Mayor quedan en la zona Alta, sin importar la probabilidad. Por lo tanto, los controles preventivos, que reducen la probabilidad, no bastan para llevar R1, R3 y R4 a la tolerancia. También se necesitan controles que reduzcan el impacto, como la conmutación a la infraestructura redundante, la reversión de órdenes no autorizadas a partir de la bitácora y la operación con el plan de contingencia. En R2, de impacto Moderado, basta con bajar la probabilidad a Media o menos para llegar a la zona Moderada.

3. Evaluación del Estado Actual y Análisis de Brechas

Los ensayos previos y la entrega del primer corte dejan una línea base de hallazgos técnicos y conceptuales. Sobre esa base, esta sección contrasta la operación real del Centro de Control Integrado (CCI) con el estado objetivo y fija los requerimientos de arquitectura, procesos

y seguridad necesarios para cerrar la brecha.

Siguiendo la metodología de evaluación propuesta por **moyle2020practical<empty citation>**, este diagnóstico analiza la postura de seguridad bajo tres dimensiones complementarias: efectividad, madurez y eficiencia.

3.1. Efectividad (Capacidad de Reducción de Riesgo)

La efectividad mide la capacidad real de los controles instalados para mitigar los riesgos inherentes de nivel alto identificados en la operación (R1, R2, R3/R7 y R4/R6). En el estado actual, esta capacidad tiene debilidades operativas y arquitectónicas relevantes.

Control de acceso y autenticación (efectividad limitada). Aunque el sistema tiene inicio de sesión único (SSO) federado mediante Active Directory y ADFS, la autenticación multifactor (MFA) todavía no se exige de manera obligatoria en la totalidad de las consolas operativas. Adicionalmente, la matriz de roles RBAC se encuentra en proceso de consolidación, lo que mantiene abierta la exposición del Sistema de Despacho ante incidentes de suplantación de credenciales o ejecución indebida de órdenes de regulación.

Integridad de telemetría (efectividad baja). Las señales GPS/AVL se transmiten en tiempo real mediante canales celulares privados (APN). Sin embargo, al carecer de validación criptográfica en origen (firma o HMAC) y de filtros automáticos de plausibilidad física en la pasarela de ingestión, la capacidad para prevenir la inyección de tramas falsas o manipuladas es reducida. Esto permite que datos anómalos o adulterados puedan ingresar al motor de despacho y distorsionar la analítica operacional.

Disponibilidad y resiliencia (efectividad insuficiente). En el perímetro local se cuenta con una suite de seguridad consolidada (Fortinet: FortiGate, FortiSIEM y FortiAnalyzer). No obstante, toda la operación lógica y física se encuentra concentrada en una única sede (Edificio Elemento), sin un esquema probado de conmutación automática (*failover*) hacia un centro de contingencia (DRP) ni una redundancia híbrida completa con Google Cloud Platform (GCP). Por tanto, la sede es un Punto Único de Falla (SPOF), limitando severamente la capacidad de respuesta ante caídas de infraestructura.

3.2. Madurez (Confiabilidad y Repetibilidad de Procesos)

La madurez evalúa la formalización, documentación y repetibilidad de los procesos que soportan cada medida de seguridad:

- **Dominio de Gobierno de Identidades (IAM):** tiene una madurez en proceso de consolidación. El aprovisionamiento de cuentas opera de forma automatizada, pero los procesos de revisión trimestral de privilegios, auditoría de cuentas inactivas y segregación de funciones dependen de intervenciones manuales.
- **Dominio Criptográfico y Gestión de Dispositivos:** está en un nivel inicial de madurez. El proceso de gestión del ciclo de vida de certificados e identidades de los computadores de a bordo (unidades ITS) carece de procedimientos estandarizados y automatizados entre TransMilenio y los concesionarios de flota.
- **Dominio de Auditoría e Inmutabilidad:** tiene una madurez intermedia. Se realiza captura automática de eventos de despacho, pero la inmutabilidad de la bitácora mediante políticas WORM (*Write Once, Read Many*) en base de datos Oracle y la correlación en tiempo real en el SIEM se encuentran en fase de implementación procedimental.

3.3. Eficiencia (Relación Costo/Beneficio)

La centralización de la operación de los componentes Troncal, TransMiZonal y TransMiCable en la sala del CCI permite aprovechar mejor los recursos tecnológicos y humanos, al reducir la necesidad de mantener salas de control y consolas independientes. Esta integración es una ventaja operativa, siempre que esté acompañada de controles adecuados y mecanismos de continuidad.

Sin embargo, la falta de controles preventivos automatizados, como la validación criptográfica de la telemetría y la exigencia de MFA en todas las consolas, incrementa la carga de trabajo de los equipos de monitoreo y TIC. En consecuencia, algunas actividades que podrían resolverse mediante controles automáticos requieren verificaciones manuales y análisis adicionales ante posibles anomalías.

Por último, la ausencia de un esquema de redundancia y recuperación debidamente probado es un riesgo operativo y económico. Una interrupción prolongada del centro principal podría afectar la regulación del transporte en toda la ciudad, por lo que resulta necesario evaluar la inversión en mecanismos de contingencia frente al impacto que tendría la indisponibilidad del servicio.

3.4. Análisis de Brechas (Gap Analysis)

El análisis de brechas compara de forma directa la arquitectura actual frente a la arquitectura objetivo. Su propósito es catalogar con claridad las deficiencias técnicas de infraestructura, software y criptografía, junto con las falencias de gobernanza y procedimientos que deben resolverse para llevar al CCI a un esquema de alta resiliencia y disponibilidad.

Matriz Comparativa: Estado Actual vs. Estado Objetivo

Tabla 13

Matriz comparativa entre el estado actual y el estado objetivo del CCI

Dominio clave	Estado actual	Estado objetivo
1. Control de Acceso y Gobierno de Identidades (IAM)	SSO corporativo (AD + ADFS), con MFA opcional o parcial en las 209 consolas y perfiles RBAC en proceso de consolidación sin segregación estricta entre monitoreo y supervisión.	Autenticación federada ADFS/SSO con MFA obligatorio en el 100 % de las consolas, matriz RBAC de privilegio mínimo y evaluación dinámica de políticas mediante motor PDP/PEP.
2. Integridad de Telemetría e Integración Geoespacial (GPS/AVL)	Telemetría de más de 10.500 buses enviada sobre APN privada, pero sin firma criptográfica en unidades ITS ni validación automática de plausibilidad física al ingresar al sistema.	Firma criptográfica (HMAC/X.509) en el borde embarcado, autenticación mutua, pasarela con filtros de plausibilidad física y enrutamiento seguro hacia RabbitMQ y Oracle Spatial.
3. Auditoría, Trazabilidad e Inmutabilidad (Bitácora CCI)	Políticas de almacenamiento WORM activas para resguardar la bitácora, pero con integración síncrona incompleta hacia las consolas y sin rutinas periódicas de verificación criptográfica.	Bitácora integrada de extremo a extremo con las consolas de despacho, sellado *hash* encadenado, marcas de tiempo sincronizadas (NTP) y correlación continua en FortiAnalyzer/FortiSIEM.
4. Disponibilidad, Resiliencia y Redundancia (Infraestructura)	Operación física y lógica concentrada en una única sede (Edificio Elemento) como Punto Único de Falla (SPOF), sin conmutación automática probada hacia un sitio alterno ni nube híbrida.	Arquitectura híbrida y redundante (GCP + Datacenter Local) sin SPOF, clúster perimetral Fortinet con mitigación DoS, *failover* automatizado y objetivo de recuperación de tiempo ($RTO \leq 15$ minutos).

Nota. Elaboración propia con base en el diagnóstico técnico del CCI.

Desglose Detallado de Brechas Técnicas y de Proceso

A partir de la comparación anterior, se establecen las intervenciones prioritarias divididas entre adaptaciones de ingeniería y formalización operativa:

Dominio de control de acceso y gobierno de identidades (IAM). En lo técnico, se requiere implementar el enrolamiento obligatorio y la validación del token MFA en el acceso al Sistema de Despacho (SIRCI/FMS). También es necesario ajustar los permisos RBAC para impedir que los usuarios con perfiles de monitoreo o consulta ejecuten comandos de regulación que no corresponden a sus funciones.

En los procesos, se busca automatizar la revisión periódica de privilegios y la desactivación de cuentas inactivas. Además, se debe establecer un procedimiento institucional de auditoría trimestral que permita revisar las cuentas privilegiadas y detectar incompatibilidades entre las funciones asignadas.

Dominio de integridad de telemetría e integración geoespacial (GPS/AVL). Técnicamente, se necesita estandarizar los mecanismos criptográficos de los computadores de a bordo (unidades ITS) para garantizar la autenticidad de los mensajes transmitidos por los vehículos. De igual forma, se deben implementar mecanismos de cuarentena en el bus de eventos que permitan aislar los mensajes que no superen las validaciones de autenticidad o que presenten inconsistencias, como saltos de posición o velocidades imposibles, antes de incorporarlos a las bases de datos transaccionales.

En la operación, es necesario establecer acuerdos y procedimientos entre TransMilenio S.A. y los concesionarios para gestionar la emisión, renovación y revocación de los certificados digitales de la flota. También se deben definir pautas para tratar y reconciliar los datos cuando se presenten interrupciones de la cobertura celular.

Dominio de auditoría, trazabilidad e inmutabilidad de decisiones (bitácora CCI). La principal necesidad técnica es integrar las consolas operativas con la bitácora para registrar de manera completa y relacionada cada decisión, desde el dato de origen hasta el responsable, la instrucción impartida y el resultado obtenido. Asimismo, se propone implementar mecanismos de

encadenamiento de *hashes* que permitan detectar posibles alteraciones en los registros mediante los sistemas de monitoreo.

Hacen falta auditorías periódicas que verifiquen la integridad criptográfica de los registros almacenados bajo el esquema WORM. También es necesario formalizar un procedimiento de cadena de custodia digital que defina cómo se deben extraer, conservar y entregar las evidencias operativas durante las auditorías internas o ante requerimientos de los entes de control.

Dominio de disponibilidad, resiliencia y redundancia (infraestructura del CCI). En la infraestructura, se plantea implementar la replicación de los datos y servicios críticos entre el centro de datos local del CCI y Google Cloud Platform (GCP), definiendo el esquema de redundancia que mejor se ajuste a los requisitos de continuidad. A esto se suma la automatización de la conmutación del tráfico mediante los balanceadores de carga y los cortafuegos Fortinet, de modo que los servicios puedan recuperarse ante una falla del sitio principal.

Por último, es necesario formalizar los planes de recuperación ante desastres (DRP) y continuidad del negocio (BCP), y comprobar su efectividad mediante simulacros periódicos. Estos planes deben complementarse con manuales de contingencia y capacitación al personal del CCI para mantener la operación en condiciones degradadas y aplicar procedimientos de regulación de emergencia mediante radiocomunicaciones.

4. Modelo de Amenazas, Activos y Evaluación de Riesgos

El modelo de amenazas y riesgos del Centro de Control Integrado (CCI) parte de los activos críticos identificados durante la primera fase del proyecto y mantiene la trazabilidad con los riesgos, políticas de seguridad, mecanismos de protección y capacidades arquitectónicas desarrolladas posteriormente mediante SABSA, O-ESA y ArchiMate.

El análisis se concentra en los tres activos que soportan directamente el proceso de gestión y despacho de flota: la telemetría de flota, la bitácora de decisiones del CCI y el Sistema de Despacho. Sobre estos activos se mantienen los cuatro riesgos priorizados desde la primera fase: manipulación o suplantación de la telemetría (R1), alteración o eliminación de la bitácora operativa (R2), acceso no autorizado al Sistema de Despacho (R3) e indisponibilidad del Sistema

de Despacho (R4).

En esta sección se consolida la criticidad de los activos, caracteriza la superficie de ataque mediante la taxonomía *Data–Method–Channel* utilizada en O-ESA, recupera la valoración de riesgo definida previamente y relaciona cada riesgo con los dominios de seguridad y capacidades técnicas requeridas para alcanzar el estado objetivo de la arquitectura.

4.1. Inventario y Criticidad de Activos

La identificación de activos realizada en la primera fase determinó tres elementos de criticidad alta para la operación del CCI. Su valoración considera las propiedades de confidencialidad, integridad y disponibilidad de la información, de acuerdo con el impacto que una afectación de cada propiedad tendría sobre la regulación de la flota.

La Tabla 14 resume esta clasificación.

Tabla 14
Inventario y criticidad de los activos priorizados del CCI

ID	Activo	Confidencialidad	Integridad	Disponibilidad	Criticidad
CCI-001	Telemetría de flota	Media	Alta	Alta	Alta
CCI-002	Bitácora de decisiones del CCI	Media	Alta	Media	Alta
CCI-003	Sistema de Despacho	Media	Alta	Alta	Alta

Nota. Elaboración propia con base en la identificación y valoración de activos realizada en la primera fase del proyecto.

La telemetría de flota constituye la fuente de información utilizada para conocer la posición, velocidad y estado operacional de los vehículos. Su integridad y disponibilidad son especialmente relevantes debido a que los datos GPS/AVL alimentan el análisis operacional y las decisiones posteriores de regulación.

La bitácora de decisiones del CCI conserva la evidencia de las acciones realizadas durante la operación, incluyendo responsables, marcas de tiempo, instrucciones emitidas y resultados. Su principal necesidad de protección se concentra en la integridad, ya que una alteración o eliminación de registros afectaría la trazabilidad y la capacidad de auditoría.

Por su parte, el Sistema de Despacho es el principal activo de software mediante el cual se

ejecutan las decisiones de regulación, de tal forma que tanto su integridad como su disponibilidad son críticas, donde una modificación no autorizada puede alterar las instrucciones operacionales, mientras que su indisponibilidad puede impedir la aplicación de medidas ante retrasos, congestiones, bloqueos u otras novedades de la operación.

4.2. Caracterización de la Superficie de Ataque

Para caracterizar la superficie de ataque se mantiene la estructura empleada en el análisis O-ESA, diferenciando tres dimensiones: Data, Method y Channel. La primera corresponde a la información o elementos que pueden verse comprometidos, mientras que por Method, con este se representa el mecanismo o técnica mediante la cual puede materializarse la amenaza, y, por último, Channel identifica el canal físico o lógico a través del cual ocurre la interacción.

Esta descomposición permite evitar una visión aislada de cada amenaza y relacionarla con los puntos concretos de la arquitectura donde deben implementarse los mecanismos de protección.

Tabla 15

Caracterización de la superficie de ataque de los riesgos priorizados

Riesgo	Activo principal	Data	Method	Channel
R1	Telemetría de flota	Coordenadas GPS/AVL, velocidad, posición y estado operacional de los vehículos.	*Spoofing*, manipulación o suplantación de mensajes de telemetría.	Comunicación 4G/5G vehículo–CCI y canal de ingestión hacia el bus de eventos.
R2	Bitácora de decisiones del CCI	Registros de decisiones, responsables, marcas de tiempo, instrucciones ejecutadas y resultados.	Modificación, borrado o truncamiento de registros y abuso de privilegios.	Sistema de Despacho, base de datos y mecanismos administrativos de almacenamiento.
R3	Sistema de Despacho	Identidades, credenciales, perfiles, roles y órdenes de despacho.	Robo o uso compartido de credenciales, abuso de privilegios y escalamiento de permisos.	Consolas del CCI, infraestructura SSO y aplicaciones que conforman el Sistema de Despacho.
R4	Sistema de Despacho e infraestructura tecnológica	Estado y disponibilidad del servicio, sesiones y flujo operacional.	Falla técnica, denegación de servicio, saturación o indisponibilidad de un componente crítico.	Infraestructura local, enlaces de telecomunicaciones, red del CCI y servicios desplegados en la nube.

Nota. Elaboración propia a partir de la matriz de trazabilidad de riesgos, superficie de ataque y servicios de seguridad desarrollada mediante O-ESA.

En R1, la superficie de ataque se encuentra principalmente en la frontera entre un entorno móvil no confiable y los sistemas internos del CCI. La información se origina en las unidades ITS instaladas en los vehículos y posteriormente atraviesa las redes móviles y la pasarela de ingestión

antes de incorporarse a los sistemas que soportan la regulación de flota. Por esto es que la arquitectura objetivo requiere validar tanto la identidad del dispositivo como la autenticidad, integridad y coherencia física de cada mensaje antes de incorporarlo a la fuente autoritativa de datos.

Para R2, la superficie de ataque se concentra en los mecanismos mediante los cuales se generan, almacenan y administran los registros operacionales. El riesgo no depende solamente de un ataque externo, sino también del abuso de privilegios o de modificaciones posteriores sobre los registros. En consecuencia, la protección debe garantizar que la evidencia sea capturada automáticamente, que no dependa de la voluntad del operador y que pueda demostrarse cualquier alteración posterior.

En R3, los principales puntos de exposición corresponden a las identidades, credenciales, roles y permisos utilizados para interactuar con las consolas y con el Sistema de Despacho, y, el riesgo se materializa cuando una identidad no autorizada logra ejecutar acciones de regulación o cuando un usuario legítimo dispone de privilegios superiores a los necesarios para su función.

Finalmente, R4 presenta una superficie de ataque distribuida entre la infraestructura local, las comunicaciones y los servicios tecnológicos de los cuales depende el despacho. Además de ataques de denegación de servicio, deben contemplarse fallas de infraestructura, saturación y pérdida de componentes críticos, debido a que cualquiera de estos eventos puede afectar la disponibilidad de la operación.

4.3. Evaluación de Riesgos Residuales

La valoración desarrollada durante la primera fase permitió establecer el nivel inherente de los riesgos asociados a los activos críticos del CCI. Posteriormente, el Anexo B consolidó los controles definidos para su tratamiento y calculó la valoración residual resultante después de considerar su efecto sobre la probabilidad o el impacto.

Para mantener la trazabilidad con el resto del Blueprint, en esta sección se conserva la numeración de riesgos utilizada a lo largo del proyecto: R1 para la manipulación de telemetría, R2 para la alteración de la bitácora de decisiones, R3 para el acceso no autorizado al Sistema de

Despacho y R4 para la indisponibilidad del Sistema de Despacho.

Debe señalarse que la matriz del Anexo B utiliza una numeración diferente. En ella, la indisponibilidad aparece como R1, la manipulación de telemetría como R2, el riesgo sobre la integridad y no repudio de la bitácora como R3 y el acceso no autorizado al Sistema de Despacho como R4. Por esta razón, los valores residuales se trasladan al Blueprint según la descripción y el activo asociado a cada riesgo, y no únicamente según el identificador numérico.

La Tabla 16 presenta esta correspondencia.

Tabla 16

Correspondencia entre los riesgos del Blueprint y el Anexo B

ID Blueprint	Riesgo	ID Anexo B
R1	Manipulación o suplantación de la telemetría de flota	R2
R2	Alteración de la bitácora de decisiones del CCI	R3
R3	Acceso no autorizado al Sistema de Despacho	R4
R4	Indisponibilidad del Sistema de Despacho	R1

Nota. Se conserva la identificación utilizada en el Blueprint y se establece su correspondencia con la matriz de riesgos del Anexo B.

Controles aplicados

Los controles registrados en el Anexo B se orientan al tratamiento de los cuatro riesgos priorizados y tienen como estrategia común la reducción del riesgo.

Para R1, asociado a la manipulación o suplantación de telemetría, se plantean controles de validación criptográfica, integridad y monitoreo continuo sobre los componentes ITS para detectar alteraciones en las señales recibidas desde la flota. Para R2, enfocado en la integridad y trazabilidad de la bitácora de decisiones, se fortalecen los accesos privilegiados mediante MFA, segregación de funciones y registros de auditoría que permitan garantizar el no repudio.

Para R3, relacionado con el acceso no autorizado al Sistema de Despacho, se implementan perfiles RBAC diferenciados, MFA en las consolas del CCI, auditoría de las órdenes emitidas y mecanismos de alertamiento ante actividades no autorizadas. Finalmente, para R4, correspondiente a la indisponibilidad, se propone un plan de recuperación ante desastres

acompañado de mecanismos de redundancia, un sitio alterno de contingencia y pruebas periódicas de recuperación.

Valoración residual

La aplicación de los controles modifica la exposición de los riesgos de manera diferente. En los riesgos R1, R2 y R3, los controles preventivos reducen la probabilidad residual desde el nivel Muy Alto hasta el nivel Medio, correspondiente al 50 %. El impacto residual permanece en el nivel Mayor, con un valor del 80 %.

En R4, asociado a la disponibilidad, el control definido tiene carácter principalmente correctivo. Por esta razón, la probabilidad residual permanece en Muy Alta (100 %), mientras que el impacto se reduce al 65 %, conservándose dentro de la categoría Mayor.

La severidad residual presentada en la Tabla 17 corresponde al producto entre la probabilidad residual y el impacto residual. De acuerdo con la matriz del Anexo B, los cuatro riesgos permanecen en una zona de riesgo final Alta, por lo cual la estrategia de tratamiento definida para todos ellos continúa siendo Reducir.

Tabla 17

Consolidación del riesgo residual de los riesgos priorizados

ID	Riesgo	Prob. residual	Impacto residual	Severidad residual	Nivel residual	Tratamiento
R1	Manipulación o suplantación de telemetría	Media (50 %)	Mayor (80 %)	40 %	Alto	Reducir
R2	Alteración de la bitácora de decisiones	Media (50 %)	Mayor (80 %)	40 %	Alto	Reducir
R3	Acceso no autorizado al Sistema de Despacho	Media (50 %)	Mayor (80 %)	40 %	Alto	Reducir
R4	Indisponibilidad del Sistema de Despacho	Muy Alta (100 %)	Mayor (65 %)	65 %	Alto	Reducir

Nota. Elaboración propia con base en la valoración residual consignada en el Anexo B. Los identificadores se presentan según la nomenclatura utilizada en el Blueprint; la correspondencia con los identificadores del Anexo B se presenta en la Tabla 16.

Los resultados muestran que los controles definidos reducen de manera importante la probabilidad de materialización de los riesgos asociados a telemetría, trazabilidad y control de

acceso. Sin embargo, ninguno de los cuatro riesgos desciende todavía a una zona inferior a Alta.

Particularmente, R4 conserva una probabilidad Muy Alta debido a que la exposición del Sistema de Despacho y de la infraestructura del CCI es permanente. En este caso, la estrategia de continuidad no elimina la posibilidad de que ocurra una falla, sino que busca limitar sus consecuencias mediante mecanismos de redundancia, contingencia y recuperación.

En consecuencia, los cuatro riesgos requieren mantener una estrategia de reducción y seguimiento continuo. La permanencia del nivel residual Alto también justifica las capacidades de seguridad planteadas en la arquitectura objetivo y su incorporación en los estados de transición y en la hoja de ruta desarrollada posteriormente.

4.4. Matriz de Dominios de Seguridad

A partir de los riesgos priorizados, el análisis de brechas y las capacidades modeladas en ArchiMate, se consolidan cuatro dominios principales de intervención. Estos dominios no se definen a partir de productos específicos, sino de los requerimientos técnicos y de control que debe satisfacer la arquitectura objetivo. Las tecnologías se presentan posteriormente como mecanismos de implementación de dichos requerimientos.

Tabla 18

Matriz de dominios de seguridad para la arquitectura objetivo del CCI

Dominio de seguridad	Riesgo	Requerimientos técnicos y de control	Componentes / tecnologías de implementación
Gestión de identidad y acceso	R3	Toda interacción con funciones críticas del Sistema de Despacho debe asociarse a una identidad individual. Se requiere autenticación multifactor obligatoria, autorización basada en roles, mínimo privilegio, segregación de funciones y evaluación centralizada de políticas antes de permitir acciones de regulación.	Active Directory y ADFS para identidad federada y SSO; MFA; perfiles RBAC; repositorio de políticas; motor PDP; PEP integrados en consolas, aplicaciones e interfaces; monitoreo de eventos de autenticación y autorización.
Seguridad e integridad de telemetría	R1	Cada unidad ITS debe disponer de una identidad verificable y cada trama debe demostrar autenticidad e integridad antes de incorporarse al flujo operacional. Además, deben aplicarse validaciones automáticas de plausibilidad y cuarentena para mensajes inválidos o anómalos.	Certificados X.509 y/o mecanismos HMAC; autenticación mutua; protección criptográfica de comunicaciones; pasarela de validación; reglas de plausibilidad; bus de eventos/RabbitMQ; Oracle Spatial como repositorio geoespacial autoritativo.
Trazabilidad, auditoría e inmutabilidad	R2	Todas las decisiones críticas deben registrarse automáticamente y conservar la relación entre evento de origen, responsable, instrucción, marca de tiempo y resultado. Los registros deben protegerse contra modificación o eliminación y deben existir verificaciones periódicas de su integridad.	Bitácora centralizada; almacenamiento WORM o de solo adición; sellado y encadenamiento de hashes; sincronización temporal mediante NTP; FortiAnalyzer/FortiSIEM para correlación y alertamiento; procedimientos de cadena de custodia digital.
Disponibilidad, resiliencia y continuidad	R4	La arquitectura debe eliminar puntos únicos de falla, separar dominios de confianza, disponer de redundancia para los componentes críticos y garantizar mecanismos de recuperación y conmutación que permitan restablecer la operación dentro de los objetivos de continuidad establecidos.	Infraestructura local del CCI y Google Cloud Platform; clústeres y firewalls Fortinet; segmentación de red; balanceadores de carga; replicación de servicios y datos; failover automatizado; monitoreo de disponibilidad; DRP y BCP.

Nota. Elaboración propia a partir del análisis de brechas, las capacidades modeladas en ArchiMate y la arquitectura tecnológica de seguridad definida mediante O-ESA.

La matriz permite mantener una relación directa entre los riesgos identificados y las capacidades que deben incorporarse a la arquitectura objetivo. En este sentido, los componentes tecnológicos no constituyen por sí mismos la arquitectura de seguridad; son los mecanismos mediante los cuales se implementan requerimientos previamente derivados del riesgo y de las necesidades operacionales del CCI.

Esta trazabilidad también facilita la transición hacia la siguiente sección del Blueprint. Los dominios de identidad y acceso, seguridad de telemetría, trazabilidad de decisiones y continuidad operativa corresponden a las principales capacidades que deben evolucionar desde el estado actual hacia los estados de transición definidos en la arquitectura de migración.

5. Arquitectura de Transición y Hoja de Ruta

La transición hacia la arquitectura objetivo del CCI se plantea como una evolución progresiva de las capacidades de seguridad actualmente disponibles. El propósito no es sustituir al mismo tiempo todos los componentes existentes, sino cerrar de forma controlada las brechas identificadas en gestión de identidades, integridad de telemetría, trazabilidad de decisiones y continuidad operativa.

Las vistas de migración, proyecto e implementación y migración desarrolladas en ArchiMate permiten relacionar las brechas del estado actual con los paquetes de trabajo, entregables y estados intermedios que conducen hacia la arquitectura objetivo. De esta manera, cada cambio implementado puede vincularse con los resultados de seguridad definidos previamente y con los riesgos R1 a R4 tratados en la Sección 4.

5.1. Estados de Transición Intermedios

La arquitectura de migración establece una secuencia entre el estado actual (*AS-IS*), dos estados de transición y el estado objetivo (*TO-BE*). Cada estado representa una configuración relativamente estable de la arquitectura y permite implementar los controles de manera progresiva sin comprometer la continuidad de la operación del CCI.

El estado AS-IS corresponde a una plataforma que dispone de capacidades de seguridad existentes, pero mantiene brechas en autenticación multifactor, segregación de accesos, integridad de la telemetría, trazabilidad de decisiones y redundancia operativa.

La Transición 1 se concentra en el fortalecimiento de la gestión de identidad y acceso. En este estado se establece MFA obligatorio para las consolas y se consolida una matriz de acceso basada en roles (RBAC), reduciendo la brecha asociada a cuentas con privilegios no segregados y mecanismos de autenticación insuficientes.

La Transición 2 incorpora la autenticación de la telemetría GPS/AVL y su integración con fuentes autoritativas de información de flota. Este estado busca garantizar que la información utilizada por el Sistema de Despacho pueda ser asociada con una fuente válida y verificada antes de utilizarse para la toma de decisiones operacionales.

Finalmente, el estado TO-BE representa un ecosistema de gestión de flota confiable y de alta disponibilidad, con accesos controlados, telemetría autenticada, fuentes de datos autoritativas, trazabilidad de las decisiones y mecanismos de recuperación ante fallas. Para alcanzar este estado también deben cerrarse las brechas relacionadas con la inmutabilidad de la evidencia operacional y la resiliencia de la infraestructura.

La Tabla 19 resume la evolución propuesta.

Tabla 19
Estados de transición de la arquitectura de seguridad del CCI

Estado	Características principales	Brecha que se reduce
AS-IS	Protección existente de la plataforma, pero con MFA parcial, permisos en proceso de consolidación, telemetría sin validación criptográfica integral, trazabilidad incompleta y operación concentrada en una única sede.	Brechas de identidad y acceso, integridad de telemetría, evidencia operacional y continuidad.
Transición 1	MFA obligatorio en las consolas del CCI y consolidación de una matriz de acceso basada en roles (RBAC), aplicando mínimo privilegio y segregación de funciones.	Accesos no segregados y ausencia de MFA obligatorio en todas las consolas.
Transición 2	Autenticación de la telemetría GPS/AVL, validación de su integridad e integración con fuentes autoritativas de datos de flota.	Telemetría GPS vulnerable a manipulación, suplantación o incorporación de información no confiable.
TO-BE	Ecosistema de gestión de flota confiable y de alta disponibilidad, con accesos controlados, información GPS autenticada, fuentes de datos autoritativas, trazabilidad de decisiones y recuperación ante fallas.	Cierre de las brechas restantes de trazabilidad, inmutabilidad, redundancia y recuperación operativa.

Nota. Elaboración propia a partir de las vistas de Migration e Implementation and Migration desarrolladas en ArchiMate.

Los estados de transición no representan proyectos independientes, sino incrementos sucesivos de la arquitectura. Por esta razón, algunas capacidades comienzan a implementarse desde las primeras fases y continúan madurando hasta alcanzar el estado objetivo. Este es el caso de la trazabilidad de decisiones y de la continuidad operativa, cuyos mecanismos iniciales pueden desplegarse tempranamente, aunque su consolidación completa se produzca en fases posteriores.

5.2. Hoja de Ruta

La hoja de ruta organiza la transición arquitectónica en tres fases de implementación. Esta planificación mantiene los horizontes de 6, 12 y 24 meses definidos previamente para el despliegue gradual de las políticas y capacidades de seguridad del CCI.

La primera fase prioriza los controles cuya implementación puede generar una reducción temprana de la exposición, principalmente MFA, RBAC, registro automático de decisiones y definición de fuentes autoritativas. La segunda fase profundiza la protección de la telemetría y la trazabilidad de la información. Finalmente, la tercera fase consolida las capacidades de continuidad, redundancia híbrida y recuperación ante desastres necesarias para alcanzar el estado objetivo.

Los paquetes de trabajo se derivan de la vista de proyecto de ArchiMate y producen cuatro entregables principales: *Control de acceso seguro*, *Telemetría GPS confiable*, *Trazabilidad de los datos* y *Disponibilidad y recuperación*.

La Tabla 20 presenta la hoja de ruta consolidada.

Tabla 20

Hoja de ruta para la transición de la arquitectura de seguridad del CCI

Fase	Horizonte	Paquetes de trabajo / actividades principales	Entregables e hitos	Recursos principales
Fase 1	0–6 meses	Implementación del gobierno de identidades y accesos mediante la activación progresiva de MFA, junto con la consolidación de RBAC y la segregación de funciones. Además, se fortalece el registro automático de decisiones, se definen las fuentes autoritativas de datos y se inicia la segmentación y protección perimetral.	Control de acceso seguro con MFA obligatorio y matriz RBAC consolidada. También se dispone de registro automático de decisiones y de fuentes autoritativas identificadas.	Equipo de Seguridad y TIC, en coordinación con la Subgerencia de Operaciones y con apoyo de las plataformas IAM y demás herramientas de seguridad.
Fase 2	6–12 meses	Implementación de ciberseguridad sobre la telemetría y la integración geoespacial, incorporando identidad para los dispositivos ITS, autenticación de mensajes y validación de plausibilidad. Asimismo, se integra de forma segura el bus de eventos y se fortalecen los mecanismos WORM, el sellado de tiempo, el encadenamiento de hashes y la correlación mediante SIEM.	Telemetría GPS confiable y fuentes de datos integradas, acompañadas de trazabilidad de los datos y una bitácora fortalecida con monitoreo centralizado.	Equipo de Seguridad y TIC, junto con los responsables de los datos operacionales críticos y los concesionarios de flota, apoyados por plataformas de integración, criptografía y monitoreo.
Fase 3	12–24 meses	Implementación de redundancia híbrida y resiliencia operativa mediante la replicación de servicios y datos, junto con mecanismos de conmutación automática y la consolidación del sitio alterno. Además, se ejecutan y validan el DRP y el BCP mediante pruebas periódicas de recuperación y failover.	Disponibilidad y recuperación mediante una arquitectura híbrida redundante y un DRP probado. Como resultado, se eliminan los puntos únicos de falla y se consolida el estado TO-BE.	Infraestructura tecnológica del CCI y Google Cloud Platform, con participación del Equipo de Seguridad y TIC y apoyo de las plataformas de seguridad y continuidad.

Nota. Los horizontes de 6, 12 y 24 meses corresponden al esquema de transición definido en los análisis previos de SABSA y O-ESA. Los paquetes de trabajo y entregables se derivan de las vistas de Project e Implementation and Migration de ArchiMate.

La secuencia propuesta permite priorizar inicialmente los cambios con menor dependencia de transformaciones de infraestructura y avanzar posteriormente hacia capacidades que requieren coordinación entre aplicaciones, dispositivos ITS, concesionarios, infraestructura local y servicios en nube.

El cierre de cada fase debe estar condicionado a la verificación de sus entregables. La transición no debe considerarse completada únicamente por la instalación de una tecnología, sino cuando la capacidad correspondiente pueda ser utilizada de manera repetible, monitoreada y evaluada contra los resultados esperados de la arquitectura.

5.3. Matriz de Seguridad SABSA e Integración con Servicios O-ESA

La arquitectura de transición mantiene la trazabilidad desde los requerimientos del negocio hasta los mecanismos tecnológicos mediante la matriz SABSA. Esta matriz cruza seis niveles de abstracción —Contextual, Conceptual, Lógico, Físico, Componentes y Gestión del Servicio— con las seis preguntas fundamentales de arquitectura: qué, por qué, cómo, quién, dónde y cuándo.

La Tabla 21 sintetiza las treinta y seis perspectivas aplicadas al proceso de gestión y despacho de flota del CCI.

Tabla 21

Matriz SABSA consolidada para el Blueprint del CCI

Capa SABSA	Activos (qué)	Motivación (por qué)	Proceso (cómo)	Personas (quién)	Ubicación (dónde)	Tiempo (cuándo)
Contextual	Telemetría de flota, bitácora de decisiones y Sistema de Despacho; continuidad del servicio y objetivos de movilidad.	R1–R4, cumplimiento normativo y necesidad de operar el CCI de forma confiable y segura.	Gestión y despacho de flota: recolección, análisis, decisión y ejecución; interacción con novedades operacionales.	Gerencia General, Subgerencia de Operaciones, Dirección TIC, operadores, supervisores, concesionarios y conductores.	CCI en Bogotá, flota Troncal, TransMiZonal y TransMiCable, centro de datos y GCP.	Operación 24/7, decisiones en tiempo real, más de 40 millones de registros diarios y picos de demanda.
Conceptual	Atributos de negocio: integridad, exactitud, autorización, trazabilidad, auditabilidad, disponibilidad, recuperabilidad y confidencialidad.	Mantener los riesgos dentro del apetito definido y aplicar políticas alineadas con PESI, MSPI y demás requerimientos regulatorios.	Seguridad desde el diseño, dato único y autoritativo, integración segura, RBAC, MFA y continuidad sin punto único de falla.	Propietarios de activos, custodios TIC, usuarios operacionales y proveedores externos, con responsabilidades diferenciadas.	Dominios de seguridad del CCI, analítica, nube, enlaces externos y comunicaciones vehículo–CCI.	Revisión periódica de la arquitectura, seguimiento continuo de KPI/KRI y ventanas de mantenimiento controladas.
Lógica	Posiciones GPS/AVL, programación operacional, novedades, instrucciones de regulación, bitácora y metadatos asociados.	Políticas de control de acceso, integridad de datos, registro de decisiones, retención y gestión de cambios.	Autenticación del origen, validación de plausibilidad, autorización por rol, registro no repudiable, detección de eventos y conmutación.	Operador de monitoreo, supervisor de despacho, soporte TIC y auditor, respaldados por identidades corporativas.	Zonas lógicas segmentadas para operación crítica, analítica y acceso externo, con reglas de flujo entre ellas.	Duración de sesión, rotación de credenciales, revisiones periódicas de permisos, retención y ventanas de respaldo.
Física	Tablas geoespaciales, mensajes de telemetría autenticados y registros de bitácora protegidos mediante hash y sellos de tiempo.	Reglas de rechazo de posiciones imposibles, aprobación para cambios críticos, bloqueo ante intentos fallidos y procedimientos de contingencia.	Validación criptográfica GPS/AVL, TLS, RBAC, MFA, almacenamiento WORM, balanceo, conmutación y SIEM.	Consolas del CCI con SSO/MFA, perfiles diferenciados y controles adicionales para operaciones críticas.	Red vehículo–CCI, infraestructura local redundante, nube híbrida, firewalls, balanceadores y segmentación de red.	Sincronización horaria, sellos de tiempo, secuencia detección–decisión–ejecución y temporización de sesiones.
Componentes	Oracle Spatial/Locator, ArcGIS, almacenamiento WORM, plataforma de eventos, SIRCI/FMS y equipos ITS a bordo.	Registro de riesgos R1–R4, matriz de controles, tableros KPI/KRI y plataformas de monitoreo y análisis.	Bus de eventos y APIs, firewalls Fortinet, balanceadores, GCP, servicios criptográficos, gestores de claves y herramientas de seguridad.	Active Directory, ADFS, MFA, listas de acceso, perfiles de cargo, matriz RBAC y mecanismos de autorización.	Nodos locales y GCP, VLAN, rangos IP, interfaces, identificadores de bus y consolas.	Servicio de hora, planificación de respaldos, vigencia de certificados y alertas de expiración.
Gestión del servicio	Gestión del ciclo de vida de los activos y aseguramiento de la continuidad de los servicios de despacho.	Evaluación periódica de R1–R4, monitoreo de KRI y seguimiento de los riesgos residuales.	Operación del SIEM, respaldos, gestión de incidentes, gestión de cambios, DRP y pruebas de recuperación.	Aprovisionamiento y retiro de cuentas, capacitación, concientización y soporte a los usuarios del CCI.	Gestión de la sala del CCI, plataformas, redes, controles físicos y sitio alterno.	Revisiones semestrales, auditorías, pruebas de conmutación y plan de transición a 6, 12 y 24 meses.

La matriz permite comprobar que las tecnologías utilizadas en las capas física y de componentes no se incorporan de manera aislada, sino como mecanismos derivados de requerimientos de negocio, políticas y servicios de seguridad previamente definidos.

Servicios O-ESA y aplicación mediante PDP/PEP

La integración con O-ESA permite traducir las necesidades identificadas por SABSA en servicios técnicos de seguridad y mecanismos concretos de aplicación de políticas. En este modelo, el *Policy Decision Point* (PDP) evalúa las reglas y condiciones aplicables, mientras que los *Policy Enforcement Points* (PEP) ubicados en consolas, aplicaciones, interfaces y fronteras tecnológicas hacen cumplir la decisión correspondiente.

La Tabla 22 relaciona los cuatro dominios priorizados con los servicios O-ESA, sus principales mecanismos de implementación y el papel que cumplen los puntos de decisión y aplicación de políticas.

Tabla 22
Integración de servicios O-ESA y mecanismos PDP/PEP

Dominio	Servicios O-ESA	Contramedidas principales	Aplicación PDP/PEP
Gestión de identidad y acceso	Gestión de identidad, autenticación y control de acceso.	La protección se basa en identidad individual, SSO, MFA y RBAC, complementados con mínimo privilegio, segregación de funciones y monitoreo continuo de los accesos.	El PDP evalúa la identidad, el rol y el contexto de la solicitud. A partir de esta decisión, los PEP ubicados en las consolas, aplicaciones e interfaces permiten o bloquean la ejecución de las acciones solicitadas.
Integridad de telemetría	Servicios criptográficos, detección y aplicación de políticas.	Se utilizan identidades para los dispositivos ITS junto con autenticación mutua y protección criptográfica de las comunicaciones. Estos mecanismos se complementan con validaciones de plausibilidad y cuarentena para las tramas consideradas inválidas.	La pasarela de ingreso actúa como PEP y evita que los mensajes que no cumplen las validaciones de autenticidad e integridad sean incorporados al flujo operacional.
Trazabilidad y auditoría	Servicios de auditoría, servicios criptográficos y control de acceso.	Las decisiones se registran de forma automática y se protegen mediante almacenamiento WORM, sellado de tiempo y encadenamiento de hashes. Además, se aplican segregación de funciones y mecanismos de alertamiento ante intentos de modificación.	Las políticas determinan qué actores pueden consultar o administrar los registros. Los puntos de aplicación ubicados en la bitácora y en el almacenamiento impiden cambios no autorizados sobre la evidencia operacional.
Disponibilidad y continuidad	Protección de frontera, detección y mecanismos de aplicación de políticas.	La continuidad se soporta mediante segmentación de red, firewalls y balanceadores de carga, junto con redundancia, monitoreo y replicación de servicios. Estos mecanismos se complementan con failover automatizado, DRP y BCP.	Los controles perimetrales y de segmentación funcionan como puntos de enforcement. De esta forma, aplican las políticas de comunicación entre los distintos dominios y bloquean aquellos flujos que no se encuentren autorizados.

Nota. Elaboración propia a partir de la matriz SABSA, las políticas y servicios O-ESA y las capacidades de seguridad definidas para la arquitectura objetivo del CCI.

La combinación de SABSA, O-ESA y ArchiMate permite mantener una cadena de trazabilidad completa: las necesidades del negocio y los riesgos originan atributos y políticas de seguridad, luego, con estas políticas se traducen en servicios y mecanismos técnicos, para que después con los paquetes de trabajo se puedan implementar esos mecanismos de forma progresiva hasta alcanzar el estado TO-BE de la arquitectura.

Esta estructura permite que la hoja de ruta no se limite a un cronograma tecnológico, sino que cada iniciativa pueda justificarse a partir del riesgo que trata, el requerimiento que satisface, el servicio de seguridad que implementa y el resultado arquitectónico que debe producir.

6. Métricas

La medición de la arquitectura de seguridad permite verificar que los controles y capacidades definidos en las secciones anteriores produzcan los resultados esperados sobre la operación del CCI. Para ello se retoma el perfil de atributos de negocio desarrollado mediante SABSA, en el cual cada requerimiento de seguridad se encuentra asociado con indicadores de desempeño (*Key Performance Indicators*, KPI) e indicadores de riesgo (*Key Risk Indicators*, KRI).

Los KPI representan las metas de desempeño que debe alcanzar la arquitectura y permiten evaluar la efectividad de los controles implementados. Los KRI funcionan como mecanismos de alerta temprana y establecen umbrales amarillo y rojo que facilitan identificar desviaciones antes de que estas generen un nivel de exposición no aceptable.

Esta estructura permite relacionar directamente las métricas con los riesgos R1 a R4, así como con los dominios de seguridad, servicios O-ESA y capacidades arquitectónicas implementadas durante las diferentes fases de la hoja de ruta.

6.1. Indicadores y Métricas de Desempeño (KPI / KRI)

La Tabla 23 y la Tabla 24 consolidan los indicadores definidos para evaluar la integridad y oportunidad de la telemetría, el control de acceso, la trazabilidad de las decisiones, la disponibilidad y recuperación del servicio, el monitoreo de seguridad, la protección de datos personales y el cumplimiento normativo.

Tabla 23

Indicadores KPI y KRI de la arquitectura de seguridad del CCI (BA1–BA6)

ID	Atributo	Riesgo	KPI (meta)	KRI (amarillo / rojo)
BA1	Integridad asegurada	R1	Al menos 99,5 % de los mensajes GPS/AVL con autenticidad e integridad verificadas.	Registros rechazados o anómalos por cada 100.000: amarillo > 50; rojo > 200.
BA2	Exacta y actual	R1	Latencia de posición p95 ≤ 30 s.	Buses sin reporte vigente por más de 2 min: amarillo > 2 %; rojo > 5 %.
BA3	Autenticada y autorizada	R3	100 % de cuentas de consolas críticas con MFA y 100 % de revisiones trimestrales de permisos ejecutadas.	Accesos fuera de perfil u horario por 1.000 sesiones: amarillo > 1; rojo > 5.
BA4	Segregación de funciones	R2, R3	Cero usuarios con roles incompatibles.	Excepciones de segregación abiertas: amarillo ≥ 1; rojo ≥ 3.
BA5	Trazable y responsable	R2	Al menos 99,9 % de decisiones con registro completo.	Decisiones sin registro completo por 1.000: amarillo > 1; rojo > 5.
BA6	Auditable y no repudiable	R2	100 % de verificaciones periódicas de integridad del repositorio WORM aprobadas.	Intentos de modificar o borrar registros: amarillo = 1 bloqueado; rojo = cualquier alteración efectiva.

Tabla 24

Indicadores KPI y KRI de la arquitectura de seguridad del CCI (BA7–BA11)

ID	Atributo	Riesgo	KPI (meta)	KRI (amarillo / rojo)
BA7	Disponible	R4	Disponibilidad mensual ≥ 99,9 %.	Minutos de indisponibilidad en el mes: amarillo > 20; rojo > 43.
BA8	Continua y recuperable	R4	RTO ≤ 15 min y 100 % de pruebas semestrales de conmutación exitosas.	Días desde la última prueba exitosa: amarillo > 150; rojo > 180.
BA9	Detectable y monitoreada	R1–R4	Tiempo medio de detección ≤ 5 min en eventos críticos y al menos 95 % de activos críticos reportando al SIEM.	Alertas críticas sin atender por más de 15 min: amarillo ≥ 1; rojo ≥ 5.
BA10	Confidencial y privada	Transversal	100 % de indicadores y tableros sin datos personales identificables innecesarios.	Accesos a datos personales sin justificación: amarillo ≥ 1; rojo ≥ 3.
BA11	Cumplimiento	Transversal	Al menos 90 % de controles aplicables con evidencia vigente.	Hallazgos de auditoría vencidos: amarillo ≥ 1; rojo ≥ 3.

Los indicadores permiten evaluar diferentes dimensiones de la arquitectura. BA1 y BA2 verifican la confiabilidad y oportunidad de la telemetría utilizada por el Sistema de Despacho; BA3 y BA4 evalúan la efectividad del gobierno de identidades y la segregación de funciones; BA5 y BA6 miden la trazabilidad, integridad y capacidad probatoria de la bitácora; mientras que BA7 y BA8 permiten comprobar la disponibilidad y capacidad de recuperación del CCI.

De manera transversal, BA9 evalúa la capacidad de detección y monitoreo de eventos sobre los activos críticos, mientras que BA10 y BA11 permiten verificar respectivamente la protección de datos personales y el cumplimiento de los controles normativos aplicables.

El seguimiento de estos indicadores debe integrarse con los mecanismos de monitoreo y

auditoría definidos en la arquitectura objetivo. Los KRI que alcancen el nivel amarillo deben generar una revisión preventiva del control asociado, mientras que un umbral rojo requiere escalamiento y tratamiento prioritario por parte de los responsables de seguridad y operación.

Finalmente, las métricas deben utilizarse como insumo para revisar periódicamente el riesgo residual de R1 a R4. De esta forma, la arquitectura no se considera efectiva únicamente por la implementación de los mecanismos técnicos definidos en la hoja de ruta, sino por su capacidad demostrable para mantener la integridad de los datos, limitar accesos no autorizados, preservar la trazabilidad y sostener la disponibilidad de los servicios críticos del CCI.

7. Conclusiones